

🔗 JALON 5 — Chapitre IX : Sécurité & Conformité

Projet : CALENDRIA

Auteur : BOUGHERARA Safi

Date : 31 Mai 2026

🔗🔒 1. Politique de Sécurité Applicative (Top 10 OWASP)

L'architecture de Calendria a été conçue pour respecter rigoureusement les préconisations de sécurité de l'OWASP. Voici comment les risques majeurs sont adressés au sein de notre socle technologique (Symfony 6.4 LTS / React 19) :

🔗a) Injection SQL (A03:2021-Injection)

- **Protection native via l'ORM** : Nous utilisons **Doctrine ORM** pour toutes les interactions avec la base de données PostgreSQL. Doctrine utilise des requêtes préparées systématiques, ce qui sépare hermétiquement la logique SQL des données saisies par l'utilisateur.
- **Requêtes DQL / QueryBuilder** : Dans les repositories personnalisés (comme dans `ReservationRepository`), toutes les variables externes (telles que `$restaurantId` ou `$dateStr`) sont injectées via le mécanisme de liaison des paramètres (`->setParameter()`). Aucune concaténation brute de chaîne n'est tolérée.

🔗b) Failles XSS (A03:2021-Injection)

- **Échappement automatique React** : Notre interface d'administration étant construite sous forme de Single Page Application (SPA) avec React, toutes les variables affichées dans le JSX sont automatiquement échappées par défaut pour prévenir toute exécution de script malveillant.
- **Échappement Twig** : Pour la partie backend (pages d'erreur, profil ou administration alternative), le moteur de template Twig applique un échappement HTML par défaut sur toutes les variables injectées.

🔗c) Attaques CSRF (A01:2021-Broken Access Control)

- **Protection par Token JWT** : L'accès au Dashboard Restaurateur est sécurisé par des jetons **JSON Web Token (JWT)** signés avec une clé secrète asymétrique (géré par `LexikJWTAuthenticationBundle`).
- **Stateless API** : Les requêtes HTTP du frontend vers l'API n'utilisent pas de sessions basées sur les cookies de navigation, rendant les requêtes insensibles aux attaques de type Cross-Site Request Forgery (CSRF). Le jeton est stocké de manière sécurisée dans la mémoire de l'application React et envoyé dans les en-têtes d'autorisation (`Authorization: Bearer <JWT_TOKEN>`).

🔗d) Stockage Sécurisé des Mots de Passe (A02:2021-Cryptographic Failures)

- **Algorithmes de Hachage Robustes** : Les mots de passe des restaurateurs sont chiffrés en base de données à l'aide de l'algorithme standard **Argon2id** (ou `bcrypt`), conformément aux politiques de hachage par défaut de Symfony 6.4. Aucun mot de passe n'est stocké en clair.
- **Authentification Forte** : Un mot de passe robuste est exigé lors de la création d'un compte utilisateur pour éviter les dictionnaires de mots de passe courants.

🔗e) Contrôle d'Accès & Firewalls (A01:2021-Broken Access Control)

L'accès aux ressources est cloisonné au niveau du fichier `config/packages/security.yaml` :

- **Firewall Principal** (`/api`) : Protège tous les endpoints d'administration (gestion des restaurants, CRUD de tables et de réservations). Il exige un jeton JWT valide sous peine de renvoyer une erreur HTTP `401 Unauthorized` .
- **Firewall Public** (`/api/chatbot`) : Positionné en priorité haute (avant `/api`), il autorise les accès publics (`PUBLIC_ACCESS`) requis pour le bon fonctionnement du Widget de Chat et de la webhook Telegram, tout en restreignant les requêtes à des actions conversationnelles isolées et sans privilèges administratifs.

⚖️ 2. Conformité RGPD (Règlement Général sur la Protection des Données)

Le projet Calendria manipule des données à caractère personnel (nom des clients, numéros de téléphone, adresses e-mail). Les mesures suivantes garantissent notre conformité avec la réglementation européenne :

Exigence RGPD	Implémentation dans Calendria
Minimisation des données	Nous collectons uniquement les informations indispensables à la réservation (Nom, Téléphone, Heure et Nombre de couverts). L'adresse e-mail est optionnelle.
Consentement Explicite	Le modèle de données inclut un champ <code>consentement_rgpd</code> (valeur booléenne) lié à l'entité Client, validant que l'utilisateur a accepté le traitement de ses données pour sa réservation.
Sécurisation des Flux	Toutes les communications transitent par le protocole sécurisé HTTPS en production, chiffrant les données entre le navigateur du client, l'API Symfony, et les plateformes tierces (Telegram).
Droit à l'Oubli & Suppression	Les restaurateurs ont la possibilité de supprimer les fiches clients et leurs données historiques directement depuis le panneau d'administration, ce qui cascade les suppressions en base.

📈 3. Bilan d'Avancement (Fin Mai)

🎯 Fonctionnalités Réalisées (100% Fonctionnelles)

- ☒ Initialisation de l'API REST Symfony et de l'application React sous Docker.
- ☒ Modélisation physique et migrations Doctrine complétées (PostgreSQL).
- ☒ CRUD complets des restaurants, tables, clients et réservations.
- ☒ Intégration du Chatbot IA (Gemini 2.5 Flash) via Widget Web (canal de chat en direct).
- ☒ Extension multi-canal avec intégration d'un **Bot Telegram** en temps réel (via Webhook et Tunnel local).
- ☒ Logique d'attribution intelligente des tables (capacité minimale adéquate) et de suggestion d'alternatives horaires.
- ☒ **Plan de Salle Interactif** et **Timeline de Service** sur le tableau de bord avec tooltips détaillés au survol.
- ☒ **Mode Sombre (Dark Mode)** adaptatif persistant dans le LocalStorage.

🔄 Écart par Rapport au Planning Initial

- **SMS & WhatsApp (Optionnel)** : Remplacés avantageusement par l'intégration d'un **Bot Telegram** de réservation, offrant une démonstration fluide et totalement gratuite sans les barrières de paiement de Twilio / Meta Business API.

- Le projet est **en avance** sur les attendus fonctionnels et techniques du Jalon 5.

🔗 Plan d'Action pour Juin (Jalon 6)

1. **Optimisation & Finalisation** : Nettoyage final du code, configuration fine des variables d'environnement de production.
2. **Déploiement Continu** : Déploiement de l'application sur un serveur VPS accessible en ligne et configuration d'un nom de domaine avec certificat SSL Let's Encrypt.
3. **Rapport Final** : Consolidation du rapport de 11 chapitres intégrant la notice utilisateur et préparation des supports de présentation de la soutenance orale.